

Agent Security Compliance Report

MiroFish (666ghj)

Risk Score: **9.2** (HIGH)

COMPLIANCE STATUS: FAIL

15 BLOCK-tier findings require remediation before deployment

Scan Date: 2026-04-06 23:25:16 UTC

Target: MiroFish

Scanner Version: agent-audit 0.18.2

Report Generated: 2026-04-06 23:25:30 UTC

Based on OWASP Agentic Security Initiative (ASI) Top 10 — 2026

1. Executive Summary

30 Total Findings	30 Actionable	15 BLOCK Tier	10 WARN Tier	9.2 Risk (HIGH)	35 Files Scanned
---	-------------------------------------	-------------------------------------	------------------------------------	---------------------------------------	--

The scan analyzed **35** files and identified **30** potential security findings, of which **30** are actionable (confidence tier BLOCK, WARN, or INFO). **14** findings are rated **CRITICAL** severity. **14** findings are rated **HIGH** severity. The overall risk score is **9.2** (HIGH).

Compliance Verdict

This codebase **does not meet** agent security compliance requirements. **15** critical findings across **4** OWASP categories require remediation before production deployment. Priority areas: **Goal Hijack, Tool Misuse, Excessive Permission**.

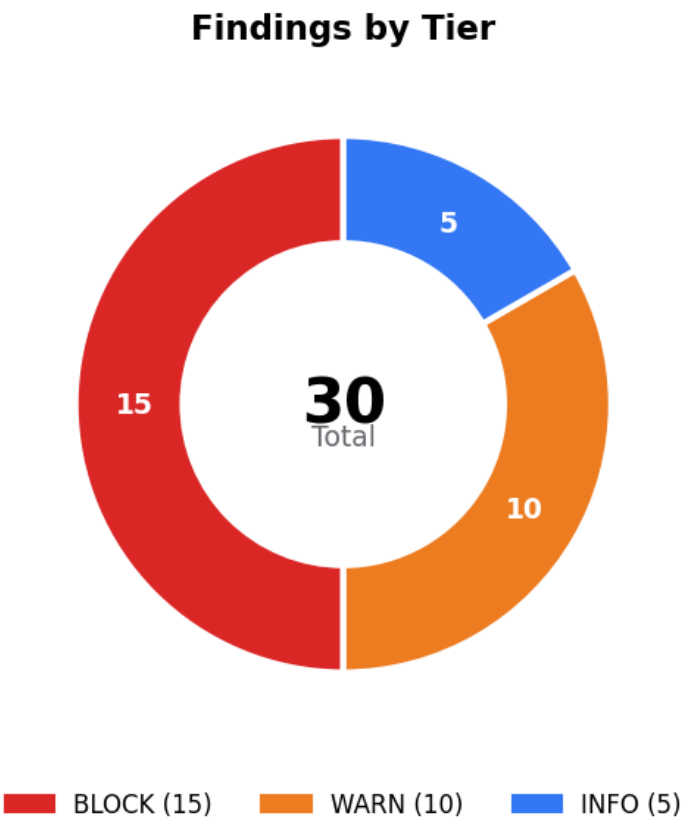
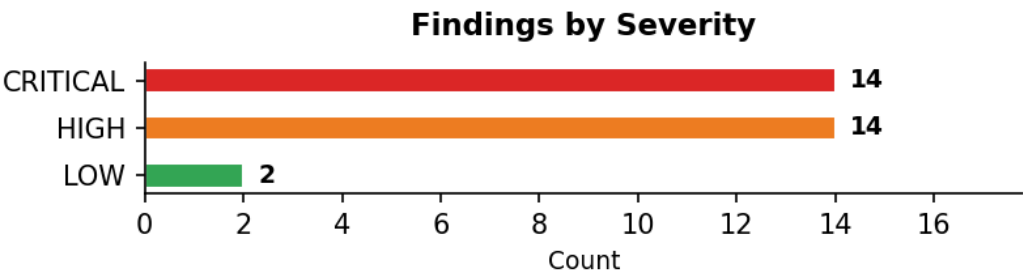
Top Risk Rules

Rule ID	Severity	Count	Impact Summary
AGENT-010	CRITICAL	14	User-controlled input is concatenated directly into system prompts or agent inst...
AGENT-034	HIGH	6	A tool function accepts string or Any parameters without performing input valida...
AGENT-115	HIGH	5	An agent process runs as a background daemon or service without TTL (time-to-liv...

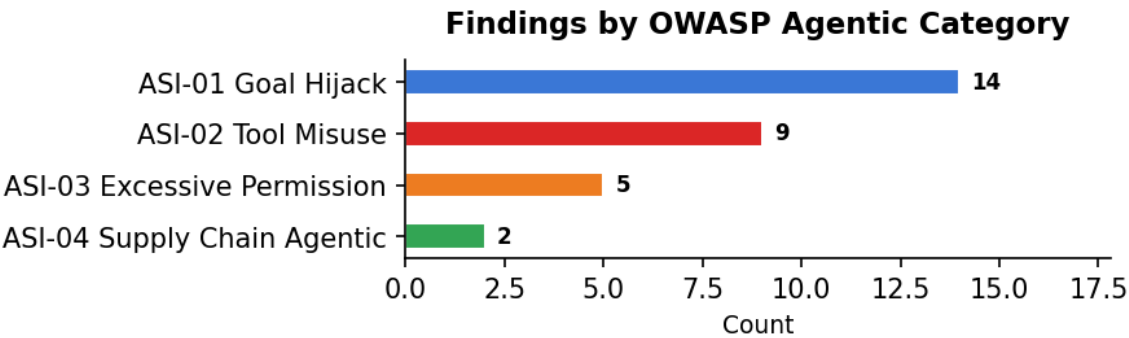
Severity Breakdown

Severity	Count	Percentage
CRITICAL	14	46.7%
HIGH	14	46.7%
LOW	2	6.7%

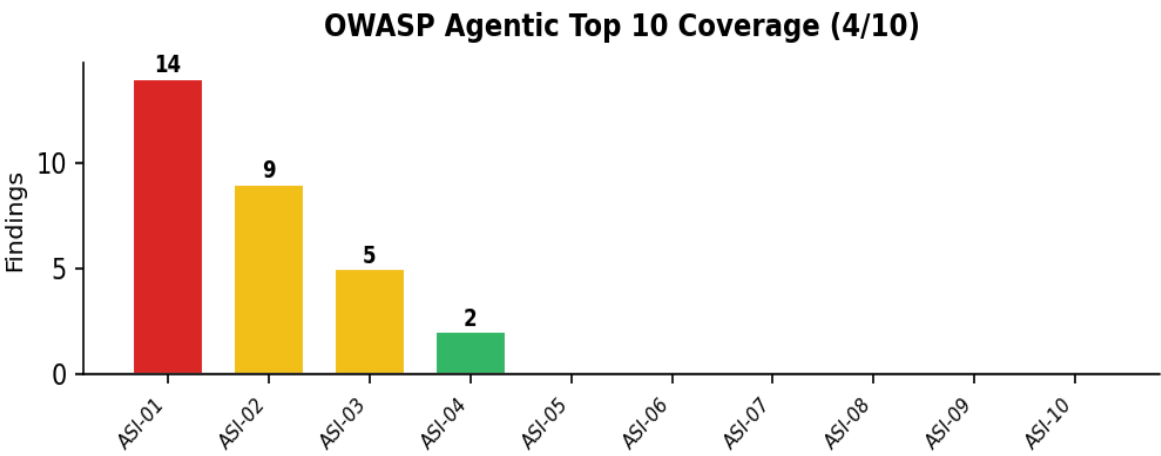
2. Visual Analysis



2b. Category Breakdown



3. OWASP Agentic Top 10 Coverage



ASI ID	Category	Findings	Status
ASI-01	Prompt Injection / Goal Hijack	14	COVERED
ASI-02	Tool Misuse	9	COVERED
ASI-03	Identity & Privilege Abuse	5	COVERED
ASI-04	Supply Chain (Agentic)	2	COVERED
ASI-05	Unexpected Code Execution	0	No findings
ASI-06	Memory Poisoning	0	No findings
ASI-07	Insecure Inter-Agent Communication	0	No findings
ASI-08	Cascading Failures	0	No findings
ASI-09	Trust Exploitation	0	No findings
ASI-10	Rogue Agent	0	No findings
Total		30	4/10 covered

4. Detailed Findings

AGENT-010 — System Prompt Injection Vector in User Input Path [CRITICAL] (14 occurrences)

User-controlled input is concatenated directly into system prompts or agent instructions without sanitization. This enables Agent Goal Hijack (ASI-01) where attackers can redirect the agent's planning and objectives.

CWE: CWE-74 | OWASP: ASI-01

Remediation: Never concatenate user input directly into system prompts. Use structured prompt templates with clear separation between system instructions and user data. Implement input validation and sanitization before passing to any prompt template.

```
# BAD: Direct concatenation
prompt = f"You are an agent. User says: {user_input}"

# GOOD: Structured separation
messages = [
    SystemMessage(content="You are a helpful agent."),
    HumanMessage(content=sanitize(user_input))
]
```

#	File	Line	Confidence
1	/tmp/MiroFish/backend/app/api/simulation.py	43	1.00
2	/tmp/MiroFish/backend/app/services/report_agent.py	1166	1.00
3	/tmp/MiroFish/backend/app/services/report_agent.py	1255	1.00
4	/tmp/MiroFish/backend/app/services/report_agent.py	1262	1.00
5	/tmp/MiroFish/backend/app/services/report_agent.py	1803	1.00
6	/tmp/MiroFish/backend/app/services/report_agent.py	1808	1.00
7	/tmp/MiroFish/backend/app/services/zep_tools.py	1699	1.00
8	...Fish/backend/app/services/oasis_profile_generator.py	675	1.00
9	...Fish/backend/app/services/oasis_profile_generator.py	690	1.00
10	...Fish/backend/app/services/oasis_profile_generator.py	739	1.00
11	.../MiroFish/backend/app/services/ontology_generator.py	210	1.00
12	.../backend/app/services/simulation_config_generator.py	589	1.00
13	.../backend/app/services/simulation_config_generator.py	706	1.00
14	.../backend/app/services/simulation_config_generator.py	870	1.00

AGENT-034 — Tool Function Without Input Validation [HIGH] (6 occurrences)

A tool function accepts string or Any parameters without performing input validation in the function body. This enables tool misuse where attackers can pass malicious inputs to trigger unauthorized actions.

CWE: CWE-20 | OWASP: ASI-02

Remediation: Add input validation at the start of tool functions. Use isinstance() checks, regex validation, or pydantic Field constraints to ensure inputs are safe before processing.

```
# BAD: No validation
@tool
def run_query(query: str) -> str:
    return cursor.execute(query)
```

```
# GOOD: With validation
@tool
def run_query(query: str) -> str:
    if not isinstance(query, str) or len(query) > 1000:
        raise ValueError("Invalid query")
    if not re.match(r"^SELECT ", query, re.IGNORECASE):
        raise ValueError("Only SELECT queries allowed")
    return cursor.execute(query)
```

#	File	Line	Confidence
1	/tmp/MiroFish/backend/app/services/simulation_runner.py	438	0.95
2	/tmp/MiroFish/backend/app/services/simulation_runner.py	736	0.65
3	/tmp/MiroFish/backend/app/services/simulation_runner.py	746	0.65
4	/tmp/MiroFish/backend/app/services/report_agent.py	167	0.54
5	/tmp/MiroFish/backend/app/services/report_agent.py	189	0.54
6	/tmp/MiroFish/backend/app/services/report_agent.py	956	0.54

AGENT-115 — Agent Background Daemon Without Lifecycle Control [HIGH] (5 occurrences)

An agent process runs as a background daemon or service without TTL (time-to-live), heartbeat checks, or graceful shutdown mechanisms. Uncontrolled agent daemons consume resources indefinitely and can persist malicious behavior beyond intended session boundaries.

CWE: CWE-400 | **OWASP:** ASI-03

Remediation: Implement TTL-based lifecycle management. Add heartbeat checks, graceful shutdown handlers (SIGTERM), and maximum session duration limits. Use a multi-gate trigger pattern for daemon activation.

```
# BAD: Daemon without lifecycle control
thread = Thread(target=agent_loop, daemon=True)
thread.start()

def agent_loop():
    while True:
        process_tasks()

# GOOD: Daemon with TTL and graceful shutdown
import signal

class AgentDaemon:
    def __init__(self, ttl_seconds=86400):
        self.ttl = ttl_seconds
        self.start_time = time.time()
        self.running = True
        signal.signal(signal.SIGTERM, self.shutdown)

    def shutdown(self, signum, frame):
        self.running = False

    def run(self):
        while self.running:
            if time.time() - self.start_time > self.ttl:
                break
            process_tasks()
```

#	File	Line	Confidence
1	/tmp/MiroFish/backend/app/api/simulation.py	611	0.85
2	/tmp/MiroFish/backend/app/api/graph.py	512	0.85

#	File	Line	Confidence
3	/tmp/MiroFish/backend/app/api/report.py	179	0.85
4	/tmp/MiroFish/backend/app/services/simulation_runner.py	463	0.85
5	...ish/backend/app/services/zep_graph_memory_updater.py	284	0.85

AGENT-047 — Subprocess Execution Without Sandbox [HIGH] (3 occurrences)

Agent executes subprocess (subprocess.Popen) without sandbox isolation. Subprocess execution with dynamic input can lead to command injection.

CWE: CWE-78 | **OWASP:** ASI-02

Remediation: Avoid shell=True. Use parameterized commands with shlex.quote(). Consider sandboxing subprocess execution with containers or restricted shells.

#	File	Line	Confidence
1	/tmp/MiroFish/backend/app/services/simulation_runner.py	438	0.80
2	/tmp/MiroFish/backend/app/services/simulation_runner.py	736	0.48
3	/tmp/MiroFish/backend/app/services/simulation_runner.py	746	0.48

AGENT-110 — Missing .npmignore in npm Project [LOW] (2 occurrences)

No .npmignore file found in npm project root. Without .npmignore, source maps, debug symbols, and environment files may be included in published packages.

CWE: CWE-540 | **OWASP:** ASI-04

Remediation: Create a .npmignore file and add patterns for *.map, *.pdb, .env, and other debug artifacts.

#	File	Line	Confidence
1	/tmp/MiroFish/package.json	1	0.65
2	/tmp/MiroFish/backend/pyproject.toml	1	0.60

5. Remediation Roadmap

Prioritized remediation plan based on severity and occurrence count.

Priorit y	Rule ID	Title	Severity	Count	Est. Effort
P1	AGENT-010	System Prompt Injection Vector in User I...	CRITICAL	14	High (Architecture Change)
P2	AGENT-034	Tool Function Without Input Validation	HIGH	6	Low (Targeted Fix)
P3	AGENT-115	Agent Background Daemon Without Lifecycl...	HIGH	5	Low (Targeted Fix)
P4	AGENT-047	Subprocess Execution Without Sandbox	HIGH	3	Low (Targeted Fix)
P5	AGENT-110	Missing .npmignore in npm Project	LOW	2	Low (Targeted Fix)

6. Methodology

This report was generated by **agent-audit v0.18.2**, a static security analyzer for AI agent code, MCP configurations, and agentic workflows.

Analysis Techniques

- **AST-based taint analysis** — Tracks data flow from user inputs through tool functions to dangerous sinks (subprocess, eval, SQL).
- **Credential detection** — Three-stage pipeline: regex matching, value entropy analysis, and contextual confidence scoring.
- **MCP configuration audit** — Validates Model Context Protocol server configs for SSRF, credential exposure, and scope issues.
- **Framework-aware analysis** — Reduces false positives by recognizing Pydantic schemas, LangChain/CrewAI internals, and test fixtures.

Confidence Scoring

Each finding receives a confidence score (0.0 — 1.0) computed from pattern specificity, context multipliers (test/infra dampening), and taint flow analysis. Scores map to actionability tiers:

Tier	Threshold	Meaning
BLOCK	>= 0.92	High confidence — should fail CI
WARN	>= 0.60	Medium confidence — review recommended
INFO	>= 0.30	Low confidence — informational
SUPPRESSED	< 0.30	Very low — hidden by default

Standards Alignment

All rules are mapped to OWASP Agentic Security Initiative (ASI) Top 10 categories and MITRE CWE identifiers. The scanner provides 10/10 coverage of the OWASP ASI Top 10.

Limitations

This is a **static analysis** report. It does not execute agent code or test runtime behavior. Some findings may be false positives due to static analysis limitations. Manual review is recommended for all BLOCK-tier findings before taking remediation action.